

- Access control
 - Authentication
 - Session management
 - Implicit trust between components
 - Enrolment secure processes
 - Decommissioning secure processes
 - Lost access-processes
- Device memory
 - Clear text username
 - Clear text passwords
 - Third-party credentials
 - Encryption keys
- Physical interface assessment
 - Firmware extraction
 - User CLI
 - Admin CLI
 - Privilege escalation
 - Reset to insecure state

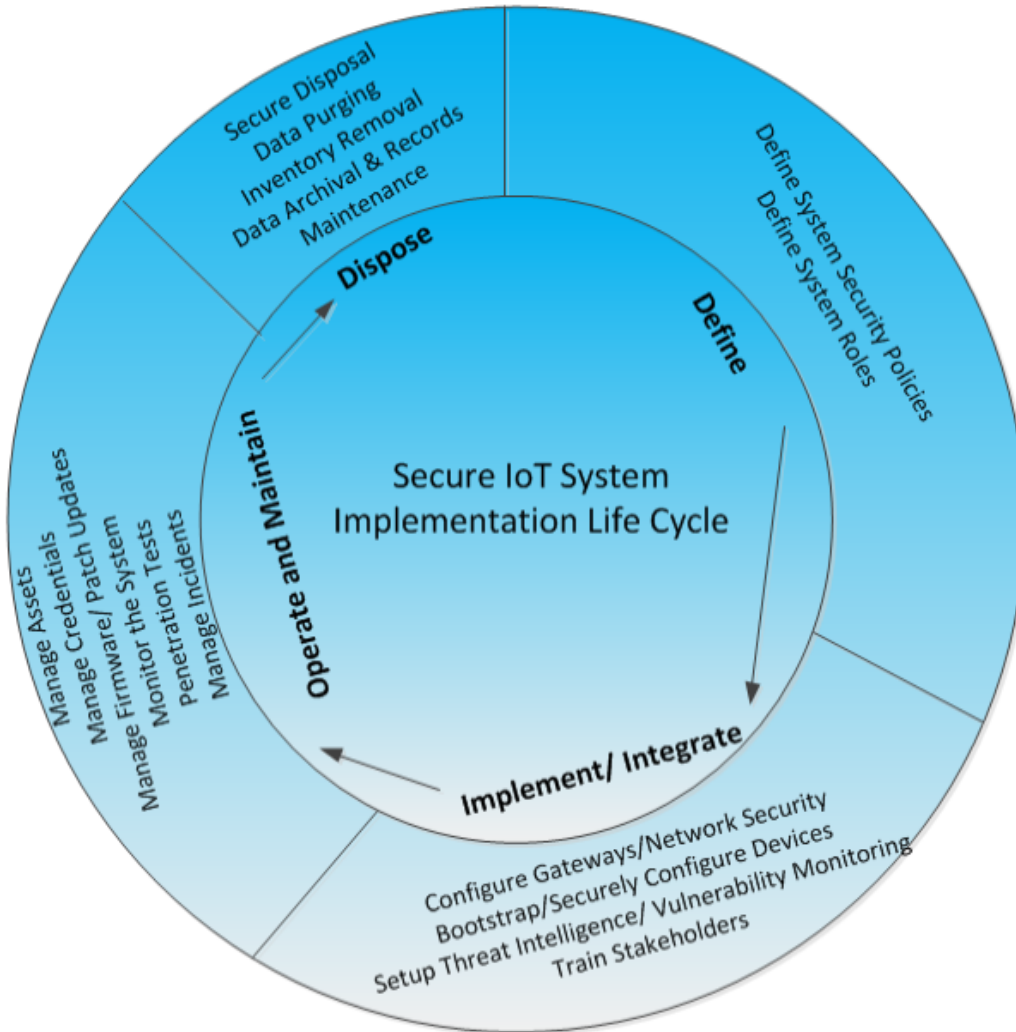
- Device web interface
 - SQL Injection
 - Cross-site scripting
 - Username enumeration
 - Weak passwords
 - Account lock out
 - Known credentials
- Device firmware
 - Hardcoded passwords
 - Sensitive URL disclosure
 - Encryption keys
- Device network services
 - Information disclosure
 - User CLI
 - Admin CLI
 - Injection
 - Denial of Service

- Administrative web interface
 - SQL injection
 - Cross-site scripting
 - Username enumeration
 - Weak passwords
 - Account lock out
 - Known credentials
- Local data storage
 - Unencrypted data
 - Data encrypted with recovered keys
 - Lack of data integrity checks
- Cloud web interface
 - SQL injection
 - Cross-site scripting
 - Username enumeration
 - Weak passwords
 - Account lock out
 - Known credentials

- Third party back-end APIs
 - Unencrypted PII sent
 - Encrypted PII sent
 - Device information leaked
 - Location leaked
- Update mechanism
 - Updates sent unencrypted
 - Updates not hash signed
 - Source location writable
- Mobile application
 - Implicitly trusted by device and cloud
 - Known credentials
 - Insecure data storage
 - Lack of transport encryption
- Vendor back-end API
 - Inherent trust of cloud or mobile application
 - Weak authentication
 - Weak access control
 - Injection attacks

- Ecosystem communications
 - Health checks
 - Heartbeats
 - Ecosystem commands
 - Decommissioning
 - Update pushes
- Network traffic
 - LAN traffic
 - LAN to Internet
 - Non-standard
 - Short-range

Connection to the Operational Security Life Cycle



- **Define:**
 - Define system security policies
 - Define system roles
- **Implement/Integrate:**
 - Configure gateways and network security
 - Bootstrap and securely configure devices
 - Set up threat intelligence and vulnerability monitoring
 - Set up deception mechanisms
 - Train stakeholders
- **Operate and maintain:**
 - Manage assets
 - Manage credentials
 - Manage firmware and patch updates
 - Monitor the system
 - Perform penetration testing
 - Manage incidents
- **Dispose:**
 - Secure disposal
 - Data purging
 - Inventory removal
 - Data archival/records maintenance